

SOC Incident Analysis Report

Sample Alert (as generated by SIEM)

Alert ID	AUTH-20345
Alert Name	Multiple Failed Logins Followed by Successful Authentication
Source IP	203.0.113.77
Target Account	j.mendes
Target System	corp-vpn-gateway01
Detection Rule	auth_failure_then_success_same_src (threshold: 5 fails / 2 min)
Time Window	09:14:02 – 09:14:51 UTC

Raw Log Excerpt

09:14:02 UTC auth-gateway FAILED_LOGIN src=203.0.113.77 user=j.mendes reason=invalid_password
09:14:09 UTC auth-gateway FAILED_LOGIN src=203.0.113.77 user=j.mendes reason=invalid_password
09:14:17 UTC auth-gateway FAILED_LOGIN src=203.0.113.77 user=j.mendes reason=invalid_password
09:14:24 UTC auth-gateway FAILED_LOGIN src=203.0.113.77 user=j.mendes reason=invalid_password
09:14:33 UTC auth-gateway FAILED_LOGIN src=203.0.113.77 user=j.mendes reason=invalid_password
09:14:38 UTC auth-gateway FAILED_LOGIN src=203.0.113.77 user=j.mendes reason=invalid_password
09:14:51 UTC auth-gateway LOGIN_SUCCESS src=203.0.113.77 user=j.mendes session_id=8841af
09:16:05 UTC auth-gateway GEOIP_LOOKUP src=203.0.113.77 country=Country-X (user's usual login country=Country-Y)

```
09:17:40 UTC vpn-gateway01 SESSION_START user=j.mendes session_id=8841af  
mfa_used=false
```

1. What Happened?

Between 09:14:02 and 09:14:38 UTC, the account **j.mendes** received six consecutive failed login attempts on the corporate VPN gateway, all originating from the same external source IP address (**203.0.113.77**). At 09:14:51 UTC, a login from that same IP **succeeded**, and a new session (session_id 8841af) was established roughly a minute later without multi-factor authentication. A GeoIP lookup shows the source IP resolves to a country that does not match the user's usual login location. This sequence is consistent with an external attacker successfully brute-forcing the account's password and then logging in from an unfamiliar location.

2. Evidence from the Logs

- **Repeated failures, single account:** Six FAILED_LOGIN events for the same user (j.mendes) within a 36-second span.
- **Consistent source IP:** Every failed attempt and the eventual successful login all originate from 203.0.113.77 — not a mix of different user IPs, which rules out normal shared-network noise.
- **Rapid, evenly-spaced timing:** Attempts occur roughly every 5–10 seconds, a cadence typical of scripted/automated login tools rather than manual human retries.
- **Successful login immediately after failures:** LOGIN_SUCCESS at 09:14:51 UTC directly follows the failure cluster with no gap, indicating the correct password was eventually found.
- **Geographic anomaly:** GEOIP_LOOKUP shows the login originated from a country different from the user's normal login country — a strong indicator the login was not performed by the legitimate user.
- **No MFA on session:** SESSION_START shows mfa_used=false, meaning password alone was sufficient to gain access — increasing the impact of the compromised password.

3. True or False Positive?

Determination: True Positive

This is a true positive. Legitimate users occasionally mistype a password once or twice, but six rapid, evenly-timed failures from one IP followed immediately by a success — combined with a login location that doesn't match the user's normal country — is not consistent with ordinary human behavior. The pattern matches known brute-force / credential-guessing tooling, and the geographic and MFA anomalies further support that this was unauthorized access rather than the real user struggling to log in.

4. Attack Type

Primary classification: Brute-force attack against the VPN authentication endpoint, resulting in **account compromise** (successful unauthorized login).

Contributing factors: Absence of MFA on the account allowed a guessed password alone to grant full session access. The short, uniform intervals between attempts suggest an automated tool rather than a human manually retrying a forgotten password.

5. Severity and Reason

Severity	Meaning	Example
Low	Minor activity	Single failed login
Medium	Suspicious activity	Multiple failed attempts
High	Confirmed attack / compromise	Successful login after brute-force

SEVERITY ASSIGNED TO THIS ALERT: HIGH

Reason: This qualifies as High severity, not Low or Medium, because the attack did not stop at repeated failures — it ended in a confirmed successful login (account compromise). The mismatched login country and lack of MFA increase confidence that this was unauthorized access, and raise the risk that the attacker now holds an active session with legitimate-looking access to internal systems.

6. Recommended Response

- **Contain:** Immediately block source IP 203.0.113.77 at the VPN gateway / firewall.
- **Terminate the session:** Kill active session 8841af for j.mendes and revoke any tokens issued during it.
- **Secure the account:** Force an immediate password reset for j.mendes and require MFA enrollment before the account can be used again.
- **Verify with the user:** Contact j.mendes directly to confirm whether they logged in from the flagged country — do not assume; the answer determines next steps.
- **Investigate session activity:** Review what the 09:17:40 session accessed — files, systems, or data — to scope the impact.
- **Check for lateral movement:** Search logs for further activity from 203.0.113.77 against other accounts or systems.
- **Escalate:** Hand off from L1 triage to L2 for full investigation and confirmed remediation, per SOC workflow.
- **Document:** Log the full timeline (alert → evidence → actions → outcome) in the incident tracking system.

7. Prevention Measures

- **Enforce MFA** on all VPN and remote-access accounts so a guessed password alone cannot grant access.
- **Account lockout / throttling** after a small number of failed attempts (e.g., 3–5) to stop brute-force tools mid-attack.

- **Geo-blocking or geo-velocity (“impossible travel”) rules** to flag or block logins from unexpected countries.
- **Rate limiting / CAPTCHA** on the authentication endpoint to slow automated guessing.
- **SIEM rule tuning** to auto-escalate the “failures → success, same source IP” pattern to High severity automatically, as was done here.
- **Credential monitoring:** Check whether j.mendes's password appears in known breach/leak datasets, since a leaked password is a common enabler of successful brute-force attempts.

8. SOC Workflow Reference (Role Mapping)

Tier	Responsibility
L1 – Detect	Monitor alerts, perform initial triage, and escalate suspicious incidents.
L2 – Investigate	Analyse logs, confirm the attack, and perform response actions.
L3 – Improve	Threat hunt, create/tune detection rules, and improve security monitoring.
